B04 — Register kerentanan & VEX

© 2026 Dea Saka Kurnia Putra. All rights reserved.

Kontrol dokumen	
ID dokumen	B04
Judul	Register kerentanan & VEX
Versi	0.1.0 (= versi aplikasi) · commit `4a4a942`
Tanggal	2026-10-23
Status	Draf
Klasifikasi	Internal
Pemilik	Dea Saka Kurnia Putra
Penyusun	Dibangkitkan oleh `scripts/compliance/*` (Claude Code) dari sumber kebenaran repo
Penyetuju	[KONFIRMASI] — penyetuju dokumen belum ditetapkan
Lingkup	Temuan pemindai rilis 0.1.0
Standar acuan	CycloneDX 1.7 VEX; NIST SP 800-218 (RV.1–RV.3)
Dokumen terkait	B01, B02, B03

Riwayat perubahan

Versi	Tanggal	Perubahan
0.1.0	2026-10-23	Versi pertama, dibangkitkan dari artefak SBOM rilis ini.

1. Ringkasan rilis 0.1.0

- Sumber temuan: `npm audit` (GitHub Advisory Database) atas seluruh pohon dependensi; osv-scanner & grype dijalankan di CI (compliance.yml).
- Total pernyataan VEX: **22** — per status: `not_affected` 22; per tingkat: high 15, low 2, medium 4, critical 1.
- Artefak yang didistribusikan (web/PWA, fungsi server, aplikasi mobile): **0 kerentanan** menurut `npm audit --omit=dev`.
- Tidak ada temuan kritis/tinggi tanpa pernyataan VEX (gate `sbom:verify`).

2. Daftar pernyataan

ID	Paket	Tingkat	Status	Justifikasi / tindakan
GHSA-c475-qrg2-pj4r	basic-ftp@5.3.1	high	not_affected	code_not_present: basic-ftp is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.

ID	Paket	Tingkat	Status	Justifikasi / tindakan
GHSA-jmr9-qjv8-65gv	extract-zip@2.0.1	high	not_affected	code_not_present: extract-zip is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-7pqw-9j4j-h8q3	extract-zip@2.0.1	high	not_affected	code_not_present: extract-zip is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-238p-pmpm-9mq7	katex@0.16.47	low	not_affected	code_not_present: katex is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-f88m-g3jw-g9cj	sharp@0.32.6	high	not_affected	code_not_present: sharp is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-rgj7-g3m4-5g8c	sharp@0.32.6	high	not_affected	code_not_present: sharp is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-wq5f-xc86-pv6w	sharp@0.32.6	high	not_affected	code_not_present: sharp is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-34x7-hfp2-rc4v	tar@7.5.22	high	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-8qq5-rm4j-mr97	tar@7.5.22	high	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-83g3-92jg-28cx	tar@7.5.22	high	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-qffp-2rhf-9h96	tar@7.5.22	high	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-9ppj-qmqm-q256	tar@7.5.22	high	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-r6q2-hw4h-h46w	tar@7.5.22	high	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.

© 2026 Dea Saka Kurnia Putra. All rights reserved. — Finandex

ID	Paket	Tingkat	Status	Justifikasi / tindakan
GHSA-vmf3-w455-68vh	tar@7.5.22	medium	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-w8wr-v893-vjvp	tar@7.5.22	medium	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-23hp-3jrh-7fpw	tar@7.5.22	critical	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-8x88-c5mf-7j5w	tar@7.5.22	high	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-gvwx-54wh-qm9j	tar@7.5.22	medium	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-r292-9mhp-454m	tar@7.5.22	high	not_affected	code_not_present: tar is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-52f5-9888-hmc6	tmp@0.1.0	low	not_affected	code_not_present: tmp is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-ph9p-34f9-6g65	tmp@0.1.0	high	not_affected	code_not_present: tmp is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.
GHSA-w5hq-g745-h8pq	uuid@7.0.3	medium	not_affected	code_not_present: uuid is a build/test tooling dependency (devDependencies tree, transitive); it is not included in the web bundle, the serverless function, or the mobile apps. Tracked for upgrade via Dependabot.

Tindakan untuk lingkungan build: paket-paket di atas dipakai oleh alat build/uji (Lighthouse CI, Capacitor CLI, mermaid, sharp) yang berjalan di mesin pengembang & runner CI. Tindakan: perbarui saat versi perbaikan tersedia melalui Dependabot; jangan menjalankan alat tersebut terhadap input yang tidak tepercaya.

3. Riwayat

Rilis	Tanggal	Temuan	Keputusan
0.1.0	2026-10-23	22	not_affected 22

© 2026 Dea Saka Kurnia Putra. All rights reserved. — Finandex